

Top 10 web hacking techniques of 2022 - nominations open



James Kettle

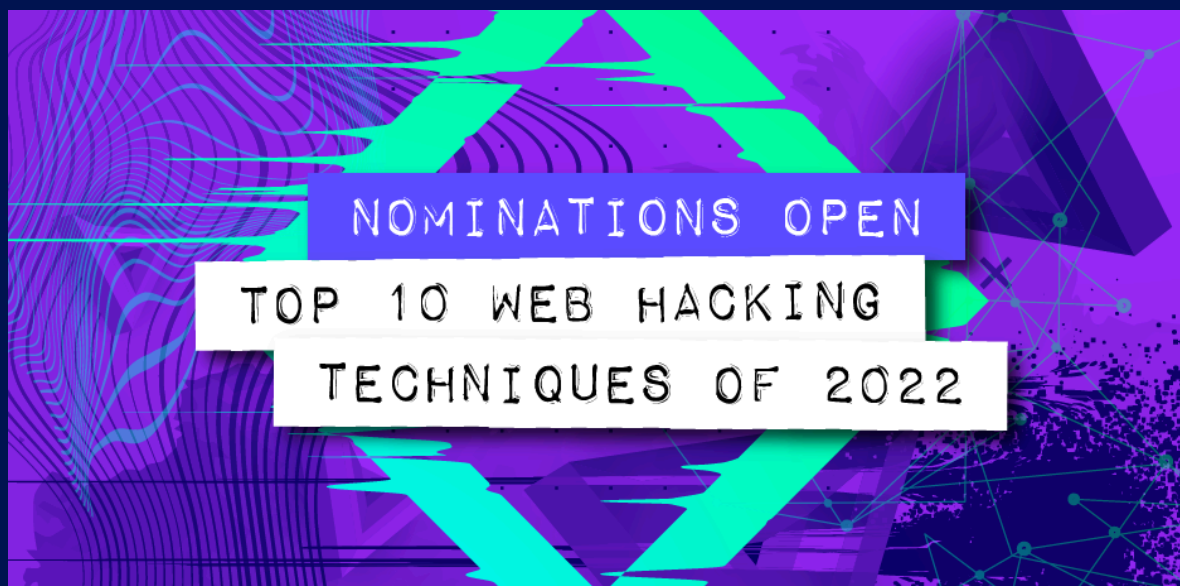
Director of Research

[@albinowax](#)



Published: Wednesday, 4 January 2023 at 13:52 UTC

Updated: Tuesday, 24 January 2023 at 12:32 UTC



Update: Voting is now closed, and the panel vote is in progress.

Nominations are now open for the top 10 new web hacking techniques of 2022!

Every year, security researchers share their latest findings with the community in a firehose of presentations, whitepapers and blog posts. While every post is valuable, some contain something special - innovative ideas and techniques that can be re-applied elsewhere.

Every year since 2006, the community has pulled together to delve through the year's findings and identify the top ten most innovative and reusable new techniques. It's time we once again dig through our notes, nominate and vote to select the top ten from 2022. If this is your first time encountering this project, you can find the full origin, history and purpose of this project on our [dedicated top 10 page](#), along with an archive of past winners and explanation of what differentiates it from related projects like the OWASP Top Ten.

This year, we'll target the following timeline:

Timeline

- **Jan 4-15:** Collect community nominations for the top research from 2022
- **Jan 17-24:** Community votes on nominations to build a shortlist of the top 15
- **Jan 24:** Launch panel vote on shortlist to select and order the 10 finalists
- **Feb 08:** Publish top 10 of 2022!

What should I nominate?

The aim is to highlight research containing novel, practical techniques that can be re-applied to different systems. Individual vulnerabilities like log4shell are valuable at the time but age relatively poorly, whereas underlying techniques such as JNDI Injection can often be reapplied to great effect. Nominations can also be refinements to already-known attack classes, such as [Exploiting XXE with Local DTD Files](#). For further examples, you might find it useful to check out [previous year's top 10s](#).

How to make a nomination:

To submit, simply provide a URL to the research, and an optional brief comment explaining what's novel about the work. Feel free to make as many nominations as you like, and nominate your own if you think it's worthy! I'll filter out weaker nominations and merge overlapping ones to keep the total number manageable.

Nominations are now closed.

We don't collect email addresses - to get notified when the voting stage starts, follow [@PortSwiggerRes](#) on Twitter or [@albinowax@infosec.exchange](#) on Mastodon

Nominations

I've made a few nominations myself to get things started, and I'll update this list with fresh community nominations every few days.

- [Disclosing information with a side-channel in Django](#)
- [PHP filters chain: What is it and how to use it](#)
- [Worldwide Server-side Cache Poisoning on All Akamai Edge Nodes](#)
- [Caching the Un-cacheables - Abusing URL Parser Confusions](#)
- [Browser-Powered Desync Attacks: A New Frontier in HTTP Request Smuggling](#)
- [Discovering Domains via a Time-Correlation Attack on Certificate Transparency](#)
- [FRAMESHIFTER: Security Implications of HTTP/2-to-HTTP/1 Conversion Anomalies](#)
- [{JS-ON: Security-OFF}: Abusing JSON-Based SQL to Bypass WAF](#)
- [Let's Dance in the Cache - Destabilizing Hash Table on Microsoft IIS!](#)
- [A story of leaking uninitialized memory from Fastly](#)
- [Hacking Salesforce-backed WebApps](#)
- [Practical client-side path-traversal attacks](#)
- [Making HTTP header injection critical via response queue poisoning](#)
- [Exploiting Inter-Process Communication in SAP's HTTP Server](#)
- [Melting the DNS Iceberg: Taking over your infrastructure Kaminsky style](#)
- [Account hijacking using "dirty dancing" in sign-in OAuth-flows](#)
- [The great SameSite confusion](#)
- [The Underrated Bugs, Clickjacking, CSS Injection, Drag-Drop XSS, Cookie Bomb...](#)
- [Persistent PHP payloads in PNGs: How to inject PHP code in an image](#)
- [Till REcollapse: : Fuzzing the web for mysterious bugs](#)

- [Exploiting Java's XML Signature Verification](#)
- [Jetty Features for Hacking Web Apps](#)
- [SSRF vulnerabilities caused by SNI proxy misconfigurations](#)
- [CSRF Resurrections Starring the Unholy Trinity](#)
- [Psychic Signatures in Java](#)
- [Deep understand ASPX file handling and some related attack vectors](#)
- [Arbitrary File Upload Tricks In Java](#)
- [Hacking the Cloud with SAML](#)
- [Apache Pinot SQLi and RCE Cheat Sheet](#)
- [The Danger of Falling to System Role in AWS SDK Client](#)
- [ElectroVolt - Pwning Popular Desktop Apps](#)
- [Hijacking service workers via DOM Clobbering](#)
- [WAF bypasses via 0days](#)
- [Exploring the World of ESI Injection](#)
- [A Magic Way of XSS in HTTP/2](#)
- [Miracle - One Vulnerability To Rule Them All](#)
- [Exploiting Arbitrary Object Instantiations in PHP without Custom Classes](#)
- [Zimbra Email - Stealing Clear-Text Credentials via Memcache injection](#)
- [SpEL Casting and Evil Beans](#)
- [Bypassing .NET Serialization Binders](#)
- [The OWASSRF + TabShell exploit chain](#)
- [Exploiting Static Site Generators: When Static Is Not Actually Static](#)
- [What is prototype poisoning? Prototype bugs explained](#)
- [In GUID We Trust](#)
- [Exploiting Web3's Hidden Attack Surface: Universal XSS on Netlify's Next.js Library](#)
- [Bypass CSP Using WordPress By Abusing Same Origin Method Execution](#)

← [Back to all articles](#)

Related Research



Burp Suite

- Web vulnerability scanner
- Burp Suite Editions
- Release Notes

Vulnerabilities

- Cross-site scripting (XSS)
- SQL injection
- Cross-site request forgery
- XML external entity injection
- Directory traversal
- Server-side request forgery

Customers

- Organizations
- Testers
- Developers

Company

- About
- Careers
- Contact
- Legal
- Privacy Notice
- Modern Slavery Statement

Insights

- Web Security Academy
- Blog
- Research
- Engineering



© 2026 PortSwigger Ltd.

